HashiCorp Certified: Terraform Associate（004）　目標 4h　#10

機密データとVault

sensitive は隠すだけ、ステートの守り方、ephemeral な変数・出力・ブロック、write-only 引数とバージョン引数、Vault プロバイダーの 2 つの使いみちと注意点、一時的な資格情報、HCP Terraform の動的な資格情報と sensitive な変数

各ページの下に、根拠にした資料（HashiCorp の Exam Content List（004）、Terraform ドキュメント v1.12.x の Manage sensitive data・Ephemeral values in resources・Use temporary write-only arguments・ephemeral block reference、HCP Terraform の Dynamic provider credentials・Manage variables、Terraform Registry の Vault Provider）を書いた。英語の原文は『』で引用した

第1章

隠すのか、残さないのか

sensitive は画面、ephemeral はファイル。

sensitive・ephemeral・write-only

しくみ	CLI・UI の表示	ステート・プラン	バージョン
sensitive = true	(sensitive value)	平文で残る	0.15
ephemeral = true	—	残さない	1.10
sensitive ＋ ephemeral	隠す	残さない	1.10
ephemeral ブロック	—	残さない	1.10
write-only 引数（_wo）	—	残さない（_wo_version だけ残る）	1.11

```
variable "database_password" {
  type      = string
  sensitive = true   # 画面で隠す
  ephemeral = true   # ファイルに残さない
}
```

sensitive を参照した式（password = var.database_password）も自動で sensitive。

terraform output -json・-raw では sensitive も平文。

出典：Manage sensitive data in your configuration

ステートを守る

リモートに置く
使う間だけメモリに置く

保存時に暗号化
HCP Terraform は自動。S3 は encrypt。GCS は顧客の鍵

アクセス制御
ステートにさわれる人を絞る

監査ログ
だれがいつ読んだかを追う

ローカルのステートは平文のファイル。Git のワークフローから外す。

設定に秘密を直接書くと、ステートとプランにも残る。

HCP Terraform の変数	ふるまい
Sensitive にチェック	write-only。本人も UI・API で見られない。値だけ変更可
資格情報	Terraform 変数より環境変数で（実行は Terraform 変数の値をすべて受け取る）

出典：Manage sensitive data（State security best practices）／Manage variables（Sensitive values）

第2章

一時的な値

実行中だけあって、どこにも残らない。

ephemeral の 3 つの形と使える場所

```
variable "api_token" {
  type      = string
  sensitive = true
  ephemeral = true
}
provider "example" {
  api_token = var.api_token     # OK：provider ブロック
}
# 子モジュールの出力（ルートには付けられない）
output "session_token" {
  value     = ephemeral.auth_provider.main.token
  ephemeral = true
  sensitive = true
}
```

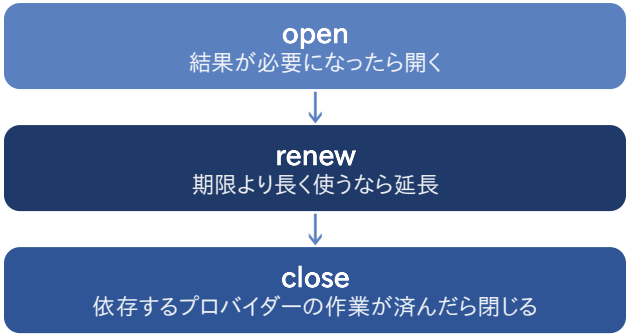
参照できる場所
locals
ephemeral = true の variable・子モジュールの output
write-only 引数
ephemeral ブロック
provider ブロック
provisioner・connection ブロック

> ふつうの引数で参照すると plan でエラー。

出典：Manage sensitive data（Omit values from state and plan files）

ephemeral ブロックと write-only 引数

```
ephemeral "random_password" "db_password" {
  length           = 16
  override_special = "!#$%&*()-_=+[]{}<>:?"
}
resource "aws_secretsmanager_secret_version" "db_password" {
  secret_id                = aws_secretsmanager_secret.db_password.id
  secret_string_wo         = ephemeral.random_password.db_password.result
  secret_string_wo_version = 1
}
resource "aws_db_instance" "example" {
  # …
  password_wo         = ephemeral.random_password.db_password.result
  password_wo_version = 1   # 変えるときは 2 に上げる
}
```



入力が計画で分からなければ apply まで遅らせる。

write-only はふつうの値も受け付けるが、ephemeral な値を渡すのがおすすめ。差分は出せない。

出典：Ephemeral values in resources／Use temporary write-only arguments／ephemeral block reference

第3章

Vault と一時的な資格情報

静的なキーを配らない。

Vault プロバイダー

```
provider "vault" {}   # VAULT_ADDR・VAULT_TOKEN で渡す
data "vault_aws_access_credentials" "creds" {
  backend = vault_aws_secret_backend.aws.path
  role    = vault_aws_secret_backend_role.role.name
}
provider "aws" {
  access_key = data.vault_aws_access_credentials.creds.access_key
  secret_key = data.vault_aws_access_credentials.creds.secret_key
}
```

使いみちは 2 つ:① Vault を設定してシークレットを入れる ② Vault から資格情報を借りてほかのプロバイダーに使う。

『Interacting with Vault from Terraform causes any secrets that you read and write to be persisted in both Terraform's state file and in any generated plan files』

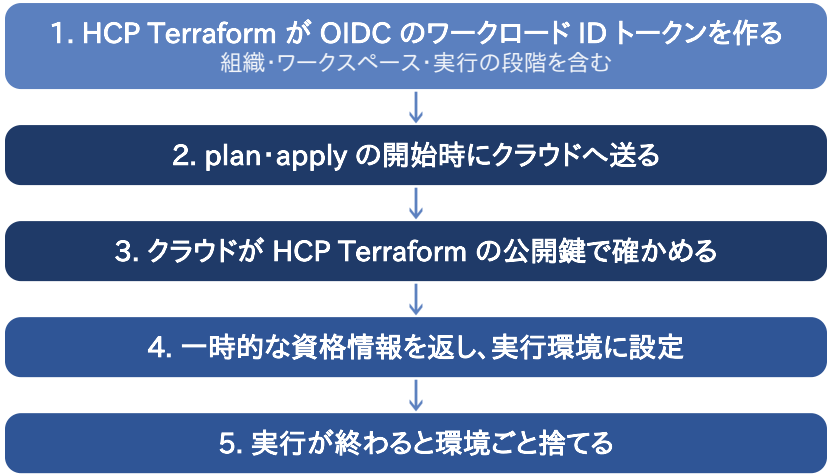
子トークン(既定 約 20 分)
期限で Vault が資格情報を取り消す。plan から時間をおくと apply が失敗しうる

AWS 用の資格情報は renew 不可
Terraform が終わるまでもつリースに

ephemeral "vault_kv_secret_v2"
ステートに残さず読み、write-only 引数へ

出典:Vault Provider／vault_aws_access_credentials／ephemeral vault_kv_secret_v2

HCP Terraform の動的な資格情報



『Dynamic provider credentials improve your security posture by letting you provision new, temporary credentials for each run.』

静的な資格情報をワークスペースに置かない。ローテーションの手間もない。

クラウド側の信頼関係のルールで、ワークスペースや実行の段階ごとに権限を絞れる。

出典：Dynamic provider credentials

本番での問われ方

ねらい	見るところ
sensitive	画面で隠すだけ、ステートには平文、参照した式も sensitive、output -json・-raw
ステート	リモート・暗号化・アクセス制御・監査ログ、Git に入れない
ephemeral	残さない、使える場所、ルートの output 不可、open・renew・close
write-only	_wo と _wo_version、更新はバージョンを上げる、差分なし
Vault	2 つの使いみち、読んだ値はステートに残る、短い TTL、環境変数で渡す
HCP	動的な資格情報（OIDC）、sensitive な変数は write-only

出典：Exam Content List（004）4h／本資料の問題演習（全 30 問）